Phase 2 – Secure Enterprise Application Access (Zero Trust Extension)

Company Size: 300 Users

---

1 Solution Overview

Phase 2 extends the Zero Trust architecture implemented in Phase 1 by securely publishing internal business applications to the internet without VPN dependency.

This phase introduces secure access for an internal web-based enterprise application hosted on an Azure Virtual Machine.

The application is published securely using:

- Microsoft Entra Application Proxy

Access is protected using advanced risk-based Conditional Access policies and device trust validation.

The design ensures:

• Internal applications are not directly exposed to the internet
• Access is identity-based instead of network-based
• Only authenticated and compliant devices can access the application

---

2 Technologies Introduced in Phase 2

Layer	Technology
Application Hosting	Microsoft Azure Virtual Machine
Secure App Publishing	Microsoft Entra Application Proxy
Identity & Access	Microsoft Entra ID
Device Compliance	Microsoft Intune
Threat Signals	Microsoft Defender for Endpoint
Session Monitoring	Microsoft Defender for Cloud Apps

---

3 Business Use Case

Organizations frequently host internal applications such as:

• HR portals
• Finance systems
• Internal dashboards
• Inventory management systems

Traditional architectures expose these systems using:

• VPN infrastructure
• Firewall port exposure

This approach introduces:

• Large attack surface
• Complex network management
• Lateral movement risks

Phase 2 eliminates these issues using identity-centric Zero Trust access control.

---

4 Application Hosting Architecture

A web application is hosted on a secure Azure Virtual Machine.

Components deployed:

• Windows Server / Linux server
• IIS / NGINX web server
• Internal web application

The application is not publicly exposed.

Instead, it is accessed through Entra Application Proxy.

---

5 Azure Application Proxy Architecture

Using:

Microsoft Entra Application Proxy

Architecture Components:

Internal Application Server
Application Proxy Connector
Microsoft Entra ID
User Device

Connection Flow:

1. User accesses application URL
2. Authentication handled by Entra ID
3. Conditional Access policies evaluated
4. Application Proxy forwards request
5. Secure outbound connection established
6. Internal application responds securely

Important security design:

- **No inbound firewall ports required**
- **Only outbound connection from connector to Entra ID**

---

6 Application Proxy Connector Deployment

The connector is installed on a server inside the network.

Functions:

- Maintains outbound connection to Entra ID
- Authenticates users
- Forwards traffic securely

Security Benefits:

- No DMZ required
- No inbound ports exposed
- Zero Trust architecture alignment

---

7 Advanced Conditional Access Policies

Phase 2 introduces risk-adaptive access policies.

Internal Web Application Policies implemented:

Application Access Policy

Applies to:

Requires:

- Multi-Factor Authentication
- Compliant device
- Entra ID joined device
- Company-owned device

Blocks:

- Personal devices
- Unmanaged browsers
- Non-compliant devices

Sign-In Risk Policy

Evaluates authentication risk signals such as:

- Impossible travel
- Anonymous IP addresses
- Suspicious login patterns

Action:

Medium risk → Require MFA
High risk → Block access

User Risk Policy

If user account risk is detected:

- **Password reset required**
- **Access temporarily restricted**

Location-Based Policy

Access allowed only from:

- Trusted locations
- Approved countries

High-risk regions automatically blocked.

Session Control Policy

Using:

Microsoft Defender for Cloud Apps

Controls include:

- Block file download on unmanaged devices
- Monitor abnormal user activity
- Prevent data exfiltration

---

8 Device Risk Integration

Threat signals from:

Microsoft Defender for Endpoint

Used within Conditional Access policies.

Risk levels evaluated:

- Low risk – normal access
- Medium risk – require MFA
- High risk – block access

Example threats detected:

• Malware infection
• Suspicious process behavior
• Credential theft indicators

---

9 Continuous Access Evaluation

Using Entra ID capabilities.

Access is re-evaluated in real time if:

• User account disabled
• Device becomes non-compliant
• Password reset occurs
• Security risk detected

Session terminated immediately if risk detected.

---

10 Monitoring & Security Visibility

Security events monitored through:

• Entra ID sign-in logs
• Conditional Access reports
• Defender alerts
• Application access logs

Administrators review:

• Failed authentication attempts
• Risky sign-ins
• Suspicious application access

---

11 End-to-End Access Flow

1. User opens application URL
2. Request redirected to Entra ID login
3. User authentication performed (MFA / Passwordless)
4. Conditional Access policies evaluated
5. Device compliance verified via Intune
6. Device risk evaluated via Defender
7. Application Proxy validates request
8. Secure connection established to internal application

Access granted only if all security conditions are satisfied.

---

12 Security Benefits

✓ Internal applications never exposed to internet
✓ No VPN dependency
✓ Identity-based application access
✓ Device health verification before access
✓ Real-time threat detection
✓ Reduced attack surface

---

13 Architecture Outcome

The organization now has a complete Zero Trust architecture across two phases.

Phase 1 provided:

Identity + Device + Data security.

Phase 2 adds:

Application-level Zero Trust protection.

The final architecture ensures:

- Only trusted identities
- Using trusted devices
- Access trusted applications
- With continuous security verification.

Final Architecture Maturity

Security Layer	**Phase**
Identity Security	Phase 1
Device Trust	Phase 1
Endpoint Protection	Phase 1
Data Protection	Phase 1
Privileged Access Governance	Phase 1
Enterprise Application Access	Phase 2
Risk-Adaptive Authentication	Phase 2
Session Monitoring	Phase 2